Receipts for AI decisions that cannot be quietly rewritten

Richard Ji · TKS focus project, AI · Build stage · github.com/thebreakthroughcourses-droid/art12-audit-log

THE PROBLEM

When an AI rejects a job applicant, proof of what it did decides who is liable. If the company can edit its own records, the records prove nothing. EU AI Act Article 12 requires high-risk AI systems to keep automatic logs, but does not say how to make them trustworthy or who may read them.

WHAT I BUILT

A Python audit log, tested with 12 tests. Every event is hash-linked to the one before it, so an edit or deletion shows up. Signed checkpoints catch the harder attack where someone edits an entry and recomputes every later hash. Personal data is kept outside the chain, so it can be erased after the 180-day retention floor without breaking the log.

My addition: an evidence-access layer. A regulator, the client company and the AI's builder each see different things, and every request to see the evidence, including refused ones, is written into the same log. Exports can be verified offline.

AGAINST THE EXISTING TOOL

I read, built and benchmarked systima's open-source aiact-audit-log (v0.2.0). It is more mature: keyed chain, write-once storage support, a command-line tool, and roughly 0.8 s versus my 5 s to write 10,000 events. Most of that gap is that it batches and skips fsync while mine writes every entry to disk. It has no access layer and no erasable content layer. Those two are where this build differs.

	aiact-audit-log v0.2.0	This build
Tamper evidence	SHA-256 chain, optional HMAC key	Chain plus signed checkpoints
Personal data	Hash or redact before logging	Separate layer, erasable after floor
Who sees evidence	Not provided	Roles, case grants, every request logged
Write 10,000 events	about 0.8 s	4.8 to 6.1 s (fsync each)

LIMITS

Tamper-evident, not tamper-proof: someone holding the signing key and write access can forge a history, and so can the same attack on their keyed chain. Timings come from one shared machine. Tests were written by the same person as the code. Not reviewed by a lawyer. The EU's high-risk deadline moved from August 2026 to 2 December 2027 per the Commission's website; I have not checked the Official Journal text.

Evidence: tests, benchmarks, tamper demo and a sample log are in the repository under evidence/ and comparison/.